

consistent, and coordinated set of support services.¹¹⁴ Service mesh and API gateways are examples of this infrastructure. In operations related to microservices, there are additional security considerations,¹¹⁵ including the following:

- The sheer number of microservices results in more interconnections and more communication links to be protected, such as through the use of ingress and egress controllers.
- The short-term and promiscuous (i.e., used by many different applications and platforms) nature of microservices calls for secure service discovery mechanisms to make sure they are registered correctly when created and removed when replaced with a new version.
- The detailed level at which microservices are built should include the ability to support the entity's security and authorization policies.
- The supporting services (e.g., authentication, authorization, and security monitoring) for microservices-based applications should be coordinated through a dedicated infrastructure.
- There is no concept of a network perimeter.
- All microservices should be treated as non-trustworthy.

The detailed nature of microservices may prompt management to centrally define security policies and configurations to enable uniform, consistent implementation across all microservices.

VII.D Artificial Intelligence and Machine Learning

AI refers to the theory and development of systems that perform tasks or functions normally associated with human intelligence, such as reasoning, learning, and self-improvement. ML is a subset of AI in which components of AI systems are used to design a sequence of actions, which could improve upon and optimize algorithms automatically through experience, to perform tasks with limited human intervention.

AI algorithms can analyze large data sets quickly and identify complex patterns, which may be used to solve problems and generate predictions or categorizations. AI can allow management to personalize customer products and services and, in certain cases, analyze real-time data to help anticipate future customer behavior. AI can also augment decision-making by identifying patterns that a human may miss when analyzing data. The automation of recurring processes and decision making can result in operational and productivity efficiencies (e.g., time and personnel reduction) by reducing human intervention.

Entities may use AI for several activities, including the following examples:

- Detection and prevention of fraud or misconduct (e.g., anti-money laundering, account compromise, and insider fraud) to reduce losses.

¹¹⁴ Refer to [NIST SP 800-204A, Building Secure Microservices-based Applications Using Service-Mesh Architecture](#).

¹¹⁵ [Ibid.](#)

- Identification, notification, and mitigation of cybersecurity breaches.
- Facilitation of automated trading (e.g., algorithmic trading).¹¹⁶
- Automation and augmentation of loan origination process, including consumer credit scoring.
- Risk management and business decision-making.
- Strengthening security controls (e.g., logical and physical access anomaly analysis and use of facial recognition for authentication).
- Compliance with applicable laws and regulations.

There are a number of risks related to the use of AI or ML. It relies on large amounts of available data, which, if breached, can result in misuse of data, fraud, financial loss, impact to an entity's reputation, or harm to consumers. There is the potential for human errors of omission or commission in the development of algorithms that can lead to incorrect decisions. Also, there is the potential for bias (intentional or unintentional) in algorithm development and use if it is not tested and validated, as well as used appropriately. For additional information on testing and validation in development, refer to the *IT Handbook's* "[Development and Acquisition](#)" booklet.

AI can lack transparency, or explainability, meaning the processing approach is difficult to follow and it can be unclear how inputs are translated into outputs. This lack of explainability can limit the understanding of the approach and affect the confidence in the reliability of the results of AI. It can also result in unintended consequences (e.g., noncompliance with applicable regulations or exceeding the entity's risk tolerance).

Another potential risk with AI is the ability to evolve on its own. This provides the ability to modify existing (or introduce new) AI variables or features without human interaction. This is known as dynamic updating, which can present challenges to monitoring and independently reviewing AI.

VII.E Internet of Things

IoT refers to the collection of technologies that allow information to be sent to and received from physical devices (e.g., security systems, HVAC systems, intelligent personal assistants, smart televisions, and other appliances), not considered previously to be IT assets, using the internet. These devices have the ability to send and receive data over a network without necessarily requiring human-to-human or human-to-computer interaction, using embedded computing capability and network connectivity and unique identifiers (e.g., IP address). IoT leverages cloud computing, mobile computing, big data, and other emerging technologies to deliver functionality. Data gathered through IoT can be used by the entity to aid in management's decision-making through improved statistical models and algorithms. IoT is found in every sector, ranging from mobile payment systems on watches and phones to internet-connected medical devices and home security devices.

¹¹⁶ In [algorithmic trading](#), firms use computers programmed with specific algorithms—sequences of steps—to identify trading opportunities and execute orders.

Because IoT includes computing devices connected to the internet and can execute code, there are a number of risks related to their use.¹¹⁷

- IoT devices interact with the physical world in ways conventional IT devices usually do not. IoT devices can make changes to physical systems; operational requirements for confidentiality, integrity, and availability of these devices, however, may be at odds with common cybersecurity and privacy practices for conventional IT devices. For example, security requirements for online and mobile payment channels often are more stringent than making purchases or payments using an intelligent personal assistant device.
- Many IoT devices cannot be accessed, managed, or monitored in the same ways as conventional IT devices. For example, most IoT devices do not support standardized mechanisms for centralized management. Administrators may not be able to fully manage an IoT device's firmware, OS, and applications. Unavailable features may include the ability to acquire, verify the integrity of, install, configure, store, retrieve, execute, terminate, remove, replace, update, and patch software. Some IoT devices lack application or human user interfaces for device use and management. When such interfaces do exist, they may not provide the functionality usually offered by conventional IT devices. In some cases, only manufacturers can perform maintenance, such as installing patches.
- An IoT device's software may be automatically reconfigured when an adverse event occurs, such as a power failure or a loss of network connectivity. For example, the security settings for an IoT device may all be reset to the default settings.
- The entity may not know what capabilities an IoT device can provide or is currently providing. The device may transfer data to manufacturer-provided cloud-based service processing and storage. Data may be sent to a cloud service to aggregate data from multiple IoT devices in a single location. These cloud services may provide access to portions of or all the devices' data, or even access to and control of the devices, for monitoring, maintenance, and troubleshooting purposes.
- There may be little or no information available about device ownership. The lack of accountability limits individuals' abilities to locate the source of and correct or delete information about themselves, or to address other problems (e.g., privacy).
- Data may still be available on some IoT devices after disposing of or transferring ownership of a device.
- IoT devices used in an entity may not be inventoried, registered, or otherwise provisioned via the normal IT processes. Previous iterations of those devices did not have networking capabilities (e.g., smart TVs that connect to an entity's network to provide teleconferencing capabilities). IoT devices often use protocols that cybersecurity and privacy controls for conventional IT cannot understand and analyze; therefore, standard network scanning devices may not recognize IoT devices (including personally owned IoT devices).

IoT devices have a number of often-unknown capabilities; therefore, it is important to understand those capabilities, the related risks, and the data devices can access. As IoT devices are relatively easy to install, it is important to understand how many devices there are and where they are used and should be considered in an entity's ITAM inventory process.

¹¹⁷ These risks are derived from [NIST IR 8228, *Considerations for Managing Internet of Things \(IoT\) Cybersecurity and Privacy Risks*](#).

APPENDIX A: EXAMINATION PROCEDURES

Examination Objectives

These examination procedures (also known as the work program) are intended to assist examiners in determining the quality and effectiveness of the entity's AIO functions and their related activities. Examiners are not limited¹¹⁸ by the examination procedures presented here and may choose to use only certain components of the work program based on the size, complexity, and nature of the entity's business. Depending on the examination scope and objectives, examiners may sample processes related to a particular line of business or review the process at an enterprise level.

Objective 1: Determine the appropriate scope and objectives for the examination.

1. Review past reports for outstanding issues or previous problems. Consider the following:
 - a. Regulatory reports of examination.
 - b. Internal and external audit reports.
 - c. Reports by independent risk management.
 - d. Independent assurance and security reports (e.g., penetration tests and vulnerability assessments) and internal reports that self-identify concerns related to AIO issues.
 - e. Regulatory, audit, and SOC reports on the entity's third-party service providers.
 - f. The entity's overall risk assessment and profile.
2. Review management's response to issues identified during or subsequent to the last examination. Consider the following:
 - a. Adequacy and timing of corrective action.
 - b. Resolution of root causes rather than symptoms.
 - c. Status of uncorrected issues.
 - d. Retesting to validate corrective action.
3. Interview management and review responses to pre-examination information requests to identify changes to the entity's technology related to new products and services that could affect the areas of review within AIO. Consider the following to identify changes:
 - a. Any significant changes in business strategy or activities that could affect the AIO environment (e.g., new lines of business or a decision to move from in-house to a cloud service provider).
 - b. Products or services delivered to either internal or external users.
 - c. Network diagrams, including configuration or component changes and the entity's internal and external connections.
 - d. Hardware, software, and telecommunications inventories.

¹¹⁸ Examiners may use system- or technology-specific technical references from authoritative sources, as appropriate.

- e. Loss of, addition to, or change in duties of key personnel, as well as any key management changes.
- f. Lists of third-party service providers and software vendors and the services or software provided.
- g. Changes to internal business processes.
- h. Changes based on industry changes or threat intelligence.

Objective 2: Management promotes and provides effective governance of AIO functions through defined responsibilities, accountability, and adequate resources to support these functions. (II, “Architecture, Infrastructure, and Operations Governance”)

1. Determine whether management implemented a process to continuously manage technology to support operational needs and mitigate AIO-related risks. Determine whether the entity’s risk management processes include the following governance mechanisms:
 - a. Delineation of board and senior management responsibilities.
 - b. Strategic planning.
 - c. ERM.
 - d. Delineation of other roles and responsibilities.
 - e. Policies, standards, and procedures.
 - f. Internal audit, independent reviews, and certifications.
 - g. Communications.
 - h. Board and senior management reporting.
2. Determine whether oversight includes the following:
 - a. Board and senior management consideration of the entity’s business objectives, including functions performed by affiliates and third-party service providers.
 - b. Management identification and evaluation of AIO-related risks, definition of short- and long-term objectives, and creation of policies and procedures to mitigate those risks.
 - c. Management consideration of security and resilience in the design of new products and services.
3. Determine whether board oversight includes the following:
 - a. Aligning AIO principles and practices with the board’s strategic plans and risk appetite.
 - b. Budgeting appropriate resources to support AIO activities.
 - c. Ensuring board members have appropriate knowledge of risks to provide a credible challenge to management.
 - d. Enabling appropriate management training on AIO to carry out its responsibilities and manage risk.
 - e. Reviewing AIO operating results and performance (e.g., audit reporting, testing results, and management and assessment reports).

4. Determine whether management oversight includes the following:
 - a. Validating through audits and other independent assessments that the following are comprehensive, meet enterprise-wide business and strategic plan objectives, and can assist in the identification of AIO-related risk.
 - Architectural designs and integration across the entity.
 - Infrastructure testing.
 - Operational testing.
 - b. Addressing risks self-identified by management, from AIO-related audits, and from other independent assessments.
 - c. Assessing and updating management's strategies and plans for AIO functions.
 - d. Promoting alignment and integration between functions of AIO.
5. Determine whether the board and senior management evaluate whether the IT strategic plan aligns with the enterprise-wide business and strategic plan, as well as established priorities and whether the planning addresses the following:
 - a. Participation of senior management by supporting AIO activities, confirming that those activities are in the IT strategic plan, reviewing the strategic planning process, and incorporating changes.
 - b. Responsibilities within the AIO functions through defining those responsibilities and determining the effectiveness of the IT strategic planning process.
 - c. Evaluation of architecture, including the entity's current architecture and whether it meets enterprise-wide business and strategic plan objectives.
 - d. Impact of IT infrastructure by understanding the relationship between IT infrastructure and the entity's needs.
 - e. Post-implementation evaluation of the performance and results of IT projects and initiatives to determine whether each project achieved the anticipated goals.
6. As part of the evaluation of question 5, determine whether management does the following:
 - a. Evaluates whether past and current IT performance demonstrates an ability to support IT strategic plans.
 - b. Takes steps to ensure and validate that IT services are delivered on time, within budget, and to business specifications.
 - c. Balances resource investments.
7. If an entity provides IT services internally or externally as a third-party service provider, determine whether management considers the following in the IT strategic planning process:
 - a. IT services strategy management that helps management to meet the needs of the entity while also providing for availability, capacity, continuity, and security.
 - b. Financial management for IT services to allocate the cost of providing services.
 - c. SPM that enables the entity to balance investment in AIO with the ability to meet business outcomes.

- d. Demand management, which balances customer demand for services with the capacity to meet that demand.
8. *This examination procedure may be coordinated with related examination procedures in the “[Management](#)” booklet.* Determine whether the entity’s ERM structure incorporates the functions of AIO. Evaluate whether, as part of ERM, there is the following:
 - a. Consistent and current review of the entity’s products, processes, applications, infrastructure, interconnectivity, and other related risks to business operations.
 - b. An effective risk management process for initiating and overseeing all AIO-related activities, including those that are outsourced, that includes:
 - Initial assessment of the AIO-related risk.
 - Architecture designed to meet the entity’s goals or objectives.
 - Infrastructure that supports the entity’s strategic objectives.
 - Identification of infrastructure assets (e.g., hardware and software) and associated interconnectivity critical to business and IT operations.
 - Ongoing monitoring that identifies and evaluates changes in risk and periodic updates to the risk profile assessment.
 - Roles, responsibilities, procedures, and reporting mechanisms for risk management in AIO activities.
 - Risk tolerances and risk and performance metrics for AIO activities.
 9. Determine whether management assigned responsibilities for the AIO functions based on the complexity of the architecture needs and assess the effectiveness of the entity’s separation of duties across the functions, particularly in situations where architecture responsibilities are combined with other functions. Evaluate the effectiveness of the assignment of the following responsibilities:
 - a. Architecture-related responsibilities:
 - Review of the centralization processes for the IT functions and understanding of interrelationships between the entity’s IT and business functions.
 - Development and maintenance of the enterprise model, including a common understanding, vocabulary, and blueprint for all stakeholders.
 - Responsibility for designing the IT architecture and accommodating IT changes.
 - Communication of challenges to the board and senior management.
 - Maintenance of representations (e.g., blueprints, network diagrams, and topologies) of the IT environment, review of existing infrastructure and operations to determine IT systems capabilities and needs.
 - Working with other members of management to evaluate architectural changes.
 - Maintenance and use of IT architecture knowledge.
 - Development of IT architecture policy and terminology.
 - Oversight of IT architecture product development, use, and refinement.
 - Maintenance and ownership of the IT architecture repository.
 - b. Data-related responsibilities:
 - Governance and use of information or data, protection of that data, and derivation of maximum value from it.

- Development of data-related policies, management of the data life cycle and the entity's data assets, oversight of compliance with applicable laws and regulations, and conformance with industry practices.
 - Provision of input to the chief architect in the design of IT systems to promote alignment with enterprise-wide business and strategic plan objectives.
 - Oversight of data management and data analysis and management of data-related projects.
 - Analysis of whether the entity's products and services meet enterprise-wide business and strategic plan objectives from a data perspective.
 - Use of data and reporting tools, maintenance of data quality, and promotion of data integrity.
 - Ownership of the entity's strategic use of data and communication of information and data analytics.
 - Definition of a data strategy, evaluation of data and its usage (including the consideration of data planning and the analytics platform), and development of metrics for monitoring data activities.
- c. Operations-related responsibilities:
- Oversight of the IT environment.
 - Management of the capacity, performance, and availability of the components used in an entity's infrastructure.
 - Support for line-of-business and functional operations.
 - Day-to-day operation and maintenance of infrastructure components.
 - Management of network infrastructure (e.g., network and connectivity, remote access, and telecommunications management) and server and device management (e.g., servers, storage, and devices).
 - Management of the IT environment (e.g., facilities, help desk, IAM, backup and replication, configuration management, resilience, and cyber and information security).
 - IT project management.
 - Database administration, systems analysis, client support, systems administration, and network administration.
10. Determine whether management documents, implements, and maintains policies, standards, and procedures related to AIO that address the following:
- a. Scope.
 - b. Responsibilities.
 - c. Accountability.
 - d. Authority.
 - e. Guidance to develop and maintain effective processes related to AIO.
11. Determine whether the board and senior management engage qualified audit or use other independent review functions to assess the AIO design, implementation, and operational effectiveness, including the adequacy of policies and procedures and the effectiveness of controls. Evaluate the appropriateness of the following:

- a. Review of the entity's AIO functions and activities and management's ability to oversee and control AIO-related risks.
 - b. Qualifications, training, and experience of auditor (or independent reviewer) in reviewing the functions and activities of AIO.
 - c. Independence of auditor from the AIO functions and activities being reviewed.
 - d. Reports to the board and senior management containing the results of audits or other independent reviews and an assessment of management's ability to oversee the entity's AIO functions and activities. Validate whether the review scope and frequency are appropriate for the complexity of the entity's AIO functions.
 - e. Whether auditors or reviewers:
 - Evaluate that management's AIO decisions align with the entity's business strategy, security, and resilience needs.
 - Leverage SOC and other external audit reports from third-party service providers.
 - Identify and report AIO issues to senior management and the board.
12. Determine whether management effectively communicates relevant AIO information to the entity's staff, applicable customers, and third parties.
13. Determine the effectiveness and comprehensiveness of board and senior management reporting related to AIO. Evaluate whether the following activities are performed:
- a. Management reports to the board periodically on the status of AIO initiatives, progress, issues, and metrics.
 - b. The board regularly monitors strategy, security, and resilience activities.
 - c. Board minutes reflect significant AIO-related discussions, credible challenge, and approvals.
 - d. Management measures performance and risks against defined baseline metrics.

The next 10 objectives (3–12) are related to section III, [“Common AIO Risk Management Topics.”](#) Each of these topics has its respective examination objective because there are risks from each area that affect the functions of AIO.

Objective 3: Management understands the common risks and mitigating controls related to data governance and data management. (III.A, [“Data Governance and Data Management”](#))

1. Determine whether management governs and manages data based on the entity-assigned data classification.
2. Evaluate whether management has an effective process for data removal or destruction when data are no longer used.
3. Evaluate whether business line management is consulted to assist in data classification, recovery standards development, and appropriate control validation.
4. Determine whether management has data governance and data management processes that include defining responsibility and processes for governing data, including the identification,

management, and oversight of any metadata, and promoting a culture that takes a data-centric approach.

5. Determine whether management identifies and classifies the entity's data effectively.
Determine whether management does the following:
 - a. Identifies and understands the nature of the entity's data, including:
 - Sensitivity, criticality, and importance of the data.
 - Frequency, recurrence, and use of the data.
 - Format in which data are maintained.
 - b. Uses the results of the data classification process to implement controls to safeguard data, including sensitive data.
 - c. Understands where data reside and maintains the effectiveness of controls over that data.
 - d. Regularly updates the information and technology asset inventories for new assets, both internal assets and those residing at third-party service provider locations.
6. Determine whether management has effective database management, including the following:
 - a. Securely designs, builds, and operates databases.
 - b. Implements a process to secure and oversee databases.
 - c. Ascertains the effectiveness of database controls and updates the information asset and technology inventories.
 - d. Ensures databases are appropriately located and structured, have sufficient capacity, and are resilient.
 - e. Regularly monitors for new or changed databases and reports on misconfigured or out-of-compliance databases.
 - f. Understands how databases interconnect throughout the entity.
 - g. Focuses on identifying, managing, and securing the data; identifying business uses; and providing appropriate access regardless of how the data are stored.
 - h. Has appropriate staff (e.g., DBAs) that
 - Is responsible for database configuration, access controls, and maintenance, as well as training.
 - Monitors databases and maintains normal operations.
 - Works with information security staff.
 - Monitors for anomalous database activities.
 - Is familiar with procedures to protect sensitive information, restores normal operations, and notifies the information security officer when necessary.
 - i. Limits and independently monitors accounts belonging to DBAs.
7. Verify that management implemented effective database security controls, such as the following:
 - a. Changes passwords for default user accounts and, subsequently, disables or deletes those accounts where possible.
 - b. Tracks and monitors activity for default accounts that cannot be disabled or deleted.